

AA Client Standards: design verification

Finny Account Aggregator flows prototype checked against Table 2 of the ReBIT “AA Client Standards-Adoption Progress Report” template (Standard v1.0.0, “Standard to enhance customer protection and user experience within Account Aggregator framework”).

Artefact reviewed	finny-aa-flows.html (45 screens, 7 flows), uploaded 09 Oct 2026
Checklist	Table 2 · Standards (as applicable to AA / FI-U), S.No 1–101
Report date	09 Oct 2026
Screen references	Each line item shows its evidence screens as captured from the uploaded prototype. Numbers 01–45 match the prototype and the annotated review PDF (screen n is on page $n+2$).
Purpose	Design evidence for the “Implemented (Yes/No)” and “Remarks” columns. This is not a submission to ReBIT; the authorised official completes the template.

101 checklist points	32 addressed in design	14 partially addressed	3 gaps in design	29 engineering / process	23 web app / SDK, not in scope
--------------------------------	----------------------------------	----------------------------------	----------------------------	------------------------------------	--

Of the 49 points that can be shown in screens, 65% are fully addressed (65% of the 43 mandatory ones). The remaining 17 are listed as actions in section 2.

Status definitions

Addressed	The prototype contains screens that meet the point. Evidence screens are listed.
Partial	Partly met in design; the remark says what is missing.
Gap	The point needs UI and no screen covers it yet.
Engineering	Technical or process control (security, audits, testing). Verify with engineering evidence; screens cannot prove it.
Not in scope	Applies to the AA web app or mobile SDK, which this mobile-app prototype does not cover.

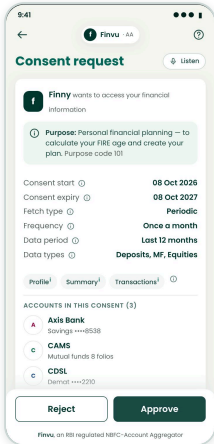
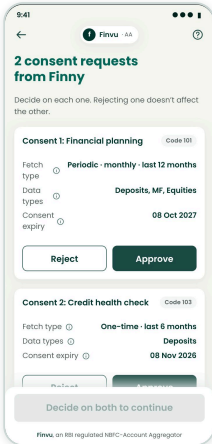
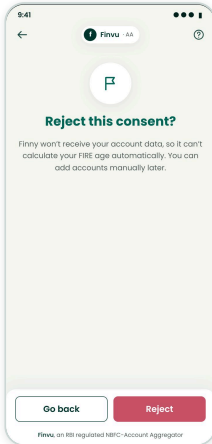
Owner: **AA** = obligation of the Account Aggregator client (Finvu); **FIU** = Finny as Financial Information User; **Both** = shared.

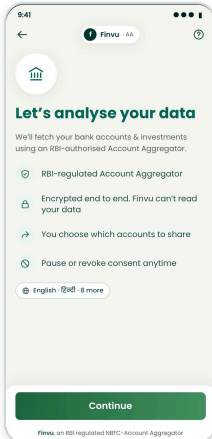
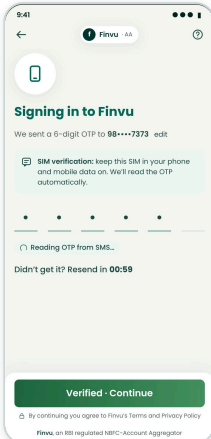
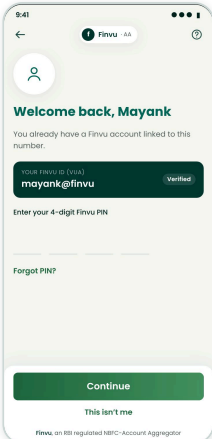
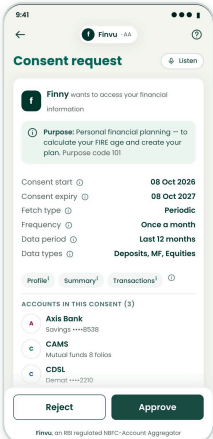
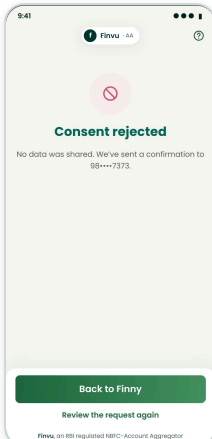
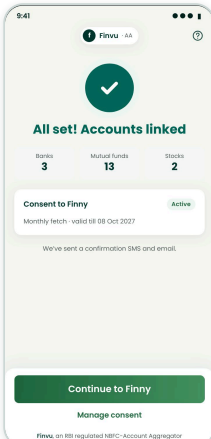
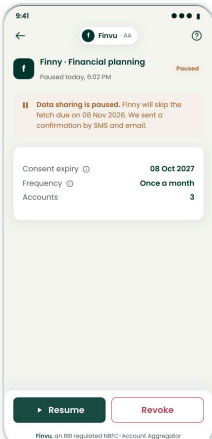
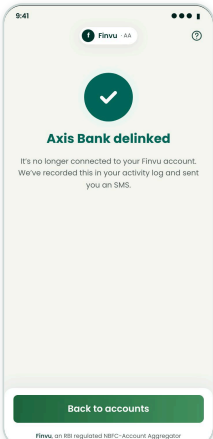
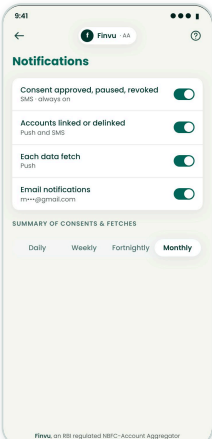
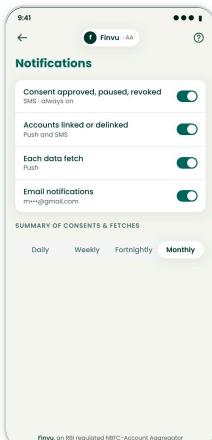
1. Summary by section

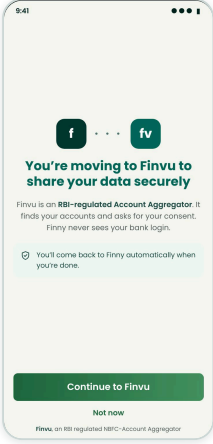
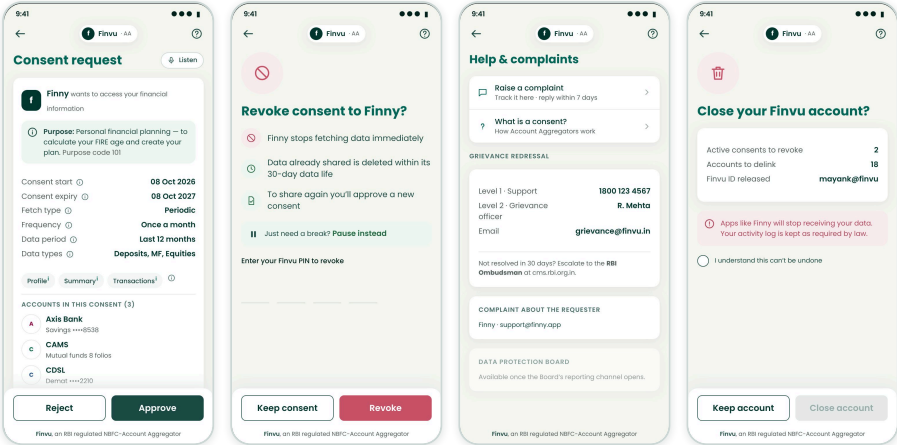
SECTION (TABLE 2)	POINTS	ADDR.	PARTIAL	GAP	ENG.	N/S	DISTRIBUTION
Customer Onboarding S.No 1–6	6	6	–	–	–	–	
Account Discovery S.No 7–8	2	2	–	–	–	–	
Consent Management standards S.No 9–19	11	9	1	–	1	–	
User Experience Standards S.No 20–31	12	6	5	1	–	–	
Technical, Security and Integration Standards S.No 32–97	66	9	7	2	28	20	
Baseline Integration method S.No 98–101	4	–	1	–	–	3	

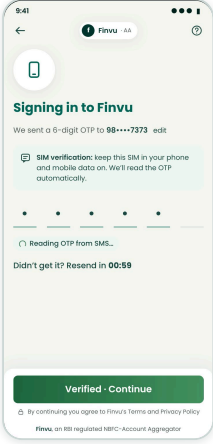
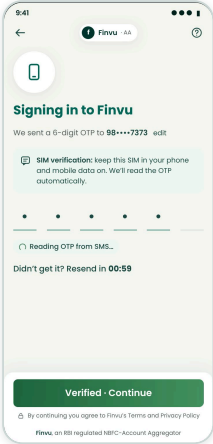
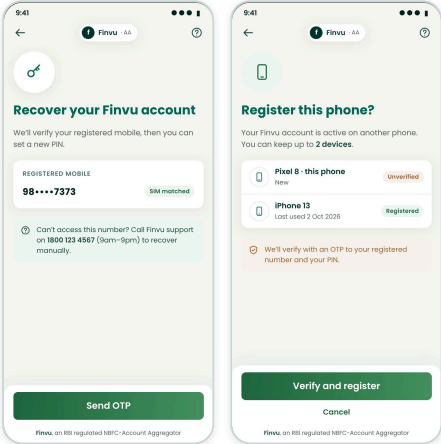
2. Actions to close before adoption

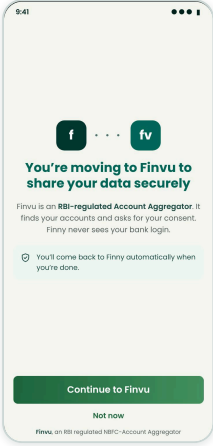
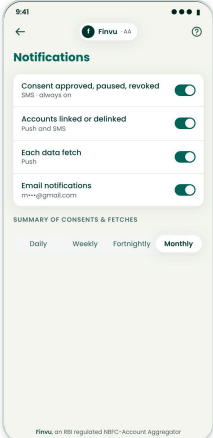
Every point marked Partial or Gap, mandatory first. Each needs a design change or an added screen.

S.NO	POINT	TYPE	STATUS	OWNER	WHAT IS MISSING
24	Usability testing and feedback mechanisms §4.1.ix · User Experience Standards No screen yet. Needs design.	Mandatory	Gap	AA	No in-app feedback entry point designed. Add a lightweight rating or feedback prompt (e.g. after success and in Help) and plan usability tests.
94	Restriction on app toggling during binding §Annex 1.6.3.iii · Technical, Security and Integration Standards No screen yet. Needs design.	Mandatory	Gap	AA	No screen tells the user to stay in the app or handles them leaving mid-binding. Add a “Don’t switch apps” notice and a restart state.
12	Approve/Reject buttons equal size and visibility, no default pre-selection §3.2.iv, 3.2.v · Consent Management standards	Mandatory	Partial	AA	Equal size and nothing pre-selected. Approve is filled and Reject outlined, which can be read as unequal visibility. Recommend matching visual weight (e.g. both outlined, or equal-contrast fills).
 12 7. Consent (summary)  14 7c. Two consents, decided separately  16 9. Reject confirmation					
21	Accessibility compliance (WCAG 2.0, alt text, contrast) §4.1.iv · User Experience Standards	Mandatory	Partial	AA	Tokens meet AA contrast for text; controls have labels. Pending: alt text for real illustrations and logos, screen-reader and large-font testing.

S.NO	POINT	TYPE	STATUS	OWNER	WHAT IS MISSING
26	AA Client displays name/logo prominently §4.2.iii · User Experience Standards	Mandatory	Partial	AA	Finvu name shown top-centre on every AA screen, but as a small text chip. Replace with the official logo at a size that is clearly legible, especially on registration and login.
    02 1. Intro 03 2. Verify mobile (SIM binding) 04 3. Existing Finvu account 12 7. Consent (summary)					
28	Real-time notifications for account linking, consent approvals/revocations §4.3.i, 4.3.iii · User Experience Standards	Mandatory	Partial	AA	Confirmations reference SMS/email and preferences exist. Not designed: push notification and SMS/email templates, and an in-app notification list.
     17 9b. Consent rejected 19 11. Success 31 17d. Paused state 37 19c. Delinked 40 Notification preferences					
29	Monthly SMS/email updates on active consents and data fetches §4.3.iv · User Experience Standards	Mandatory	Partial	AA	Monthly summary set as default in preferences. Summary SMS/email content not designed.
 40 Notification preferences					

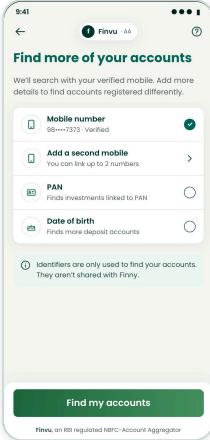
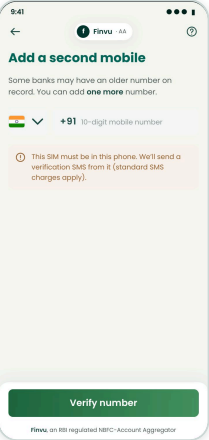
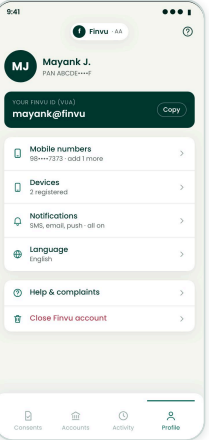
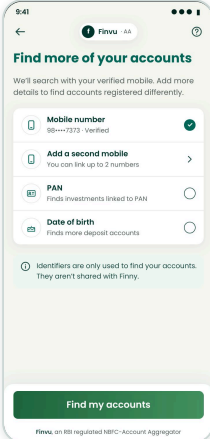
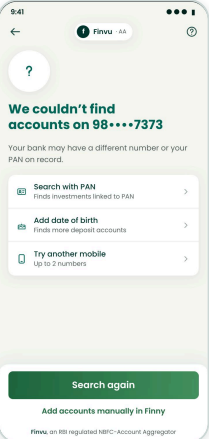
S.NO	POINT	TYPE	STATUS	OWNER	WHAT IS MISSING
38	Secure integration methods (Deep Linking, Redirection, SDK, iFrame) §5.2.i · Technical, Security and Integration Standards	Mandatory	Partial	Both	User-facing hand-off designed. Integration choice and its fallback screens are engineering; see 98.
	 01 Hand-off to Account Aggregator				
45	Compliance with DPDP Act, 2023 §5.5 · Technical, Security and Integration Standards	Mandatory	Partial	Both	Consent clarity, data life, withdrawal, complaints and account closure designed. Legal review and privacy notice pending; Data Protection Board link reserved.
	 12 7. Consent (summary) 32 17e. Revoke consent 42 Help & complaints 44 Close Finny account				
66	Version governance to phase out old versions §Annex 1.2.2.iii · Technical, Security and Integration Standards	Mandatory	Partial	AA	Engineering. A forced-update screen exists in Finny (Launch designs "App update") but not for the AA client.
84	Adherence to Android/iOS guidelines §Annex 1.4.5.i, 4.1.iii · Technical, Security and Integration Standards	Mandatory	Partial	AA	Layouts follow mobile conventions (bottom actions, sheets, back). Native component mapping and platform review pending.

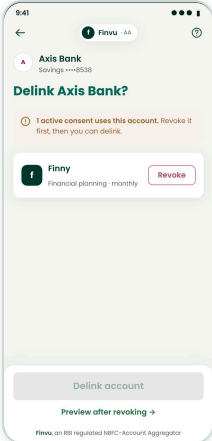
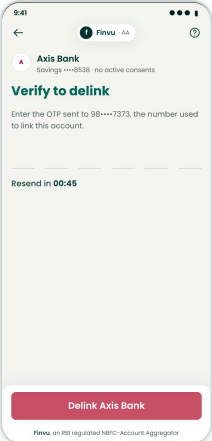
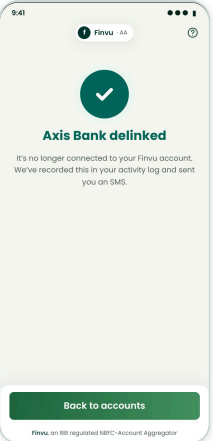
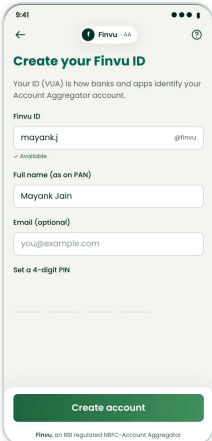
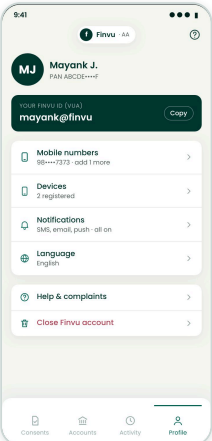
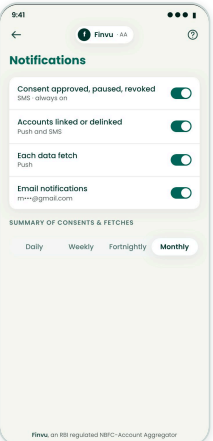
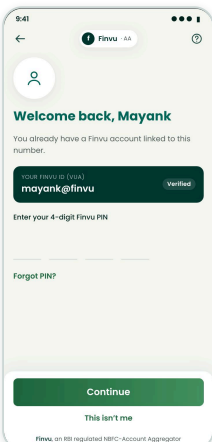
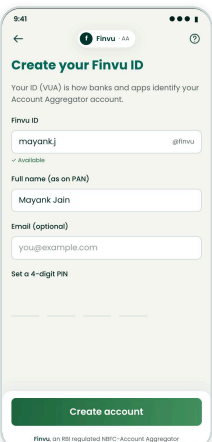
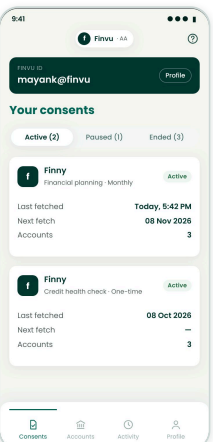
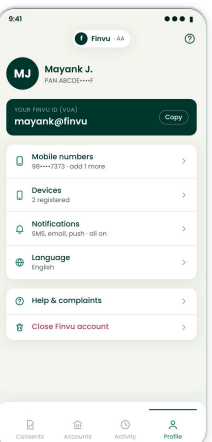
S.NO	POINT	TYPE	STATUS	OWNER	WHAT IS MISSING
88	SIM binding via outgoing SMS + OTP auto-read §Annex 1.6.1.i, 1.6.3.iv · Technical, Security and Integration Standards 	Mandatory	Partial	AA	OTP auto-read with manual entry disabled is designed. Missing: the step where the app sends the outgoing SMS (with SMS-charge notice and SIM picker for dual-SIM phones).
03 2. Verify mobile (SIM binding)					
93	Mandatory mobile data during binding §Annex 1.6.3.ii · Technical, Security and Integration Standards 	Mandatory	Partial	AA	Instruction shown. Missing: blocking state when mobile data is off or Wi-Fi only.
03 2. Verify mobile (SIM binding)					
95	Fallback authentication for SIM/device changes §Annex 1.6.3.v · Technical, Security and Integration Standards 	Mandatory	Partial	AA	Device change and recovery designed. Missing: SIM-swapped / number-changed state and re-binding flow.
06 Recover account / reset PIN 26 New device detected					

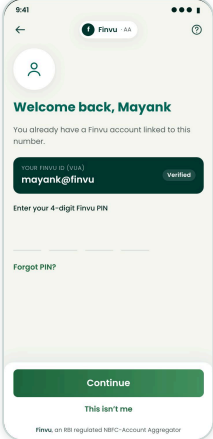
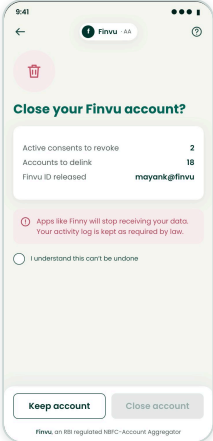
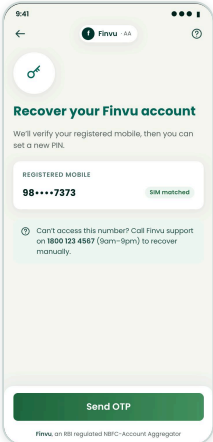
S.NO	POINT	TYPE	STATUS	OWNER	WHAT IS MISSING
98	Deep Linking integration (URL schema, Intents, Universal Links, secure tokens, fallback, user choice) §Annex 2.1 · Baseline Integration method  01 Hand-off to Account Aggregator	Mandatory	Partial	Both	Hand-off designed. Missing FI-U screens: choose among integrated AA apps (2.1.f) and “AA app not installed” store fallback with deferred deep link (2.1.e).
42	AA Client allows users to view/download financial data with explicit consent §5.3 · Technical, Security and Integration Standards No screen yet. Needs design.	Optional	Gap	AA	Optional feature not designed (customer as FI-U). If adopted, needs consent, view and download screens.
30	FI-U provides data fetch summaries with customizable frequency §4.3.v · User Experience Standards  40 Notification preferences	Optional	Partial	FIU	Frequency choice (daily, weekly, fortnightly, monthly) shown on the AA side. Finny-side summary screen and setting not designed.

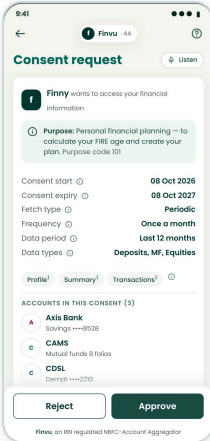
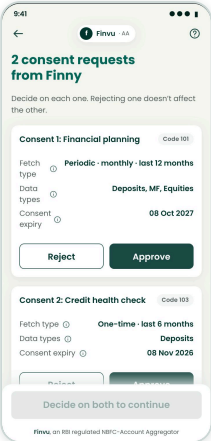
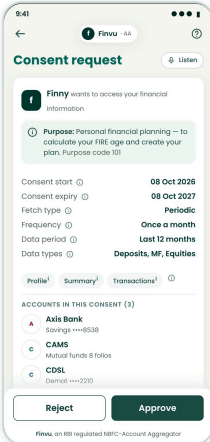
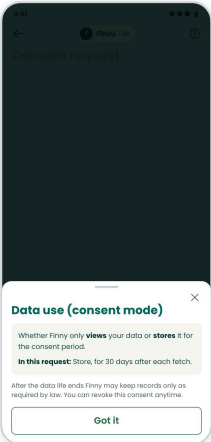
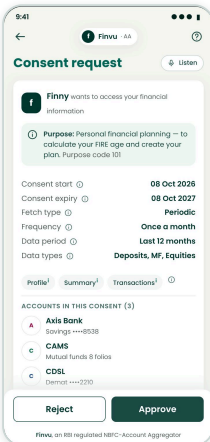
Out of scope but mandatory: 23 points cover the AA web app (browser fingerprinting, iFrame, redirection, cross-browser) and the mobile SDK. They need their own design and verification pass if Finny integrates through web or SDK rather than the AA mobile app.

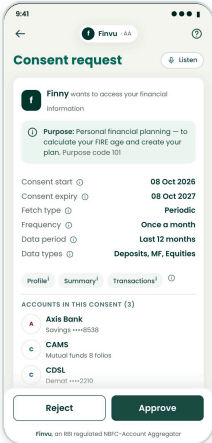
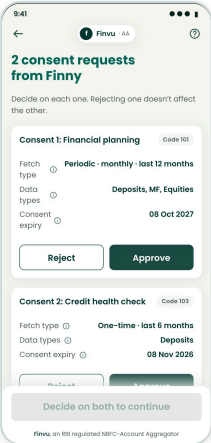
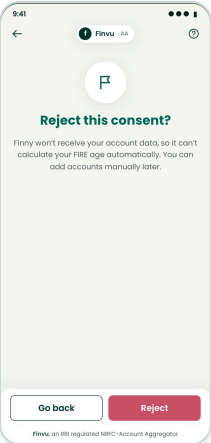
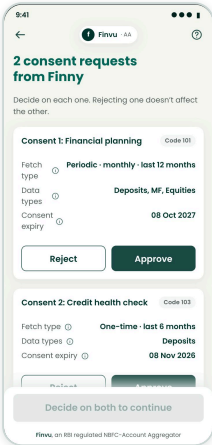
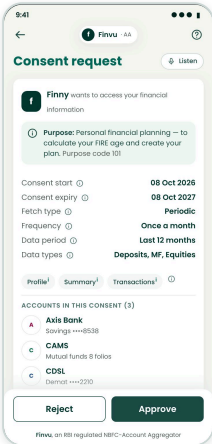
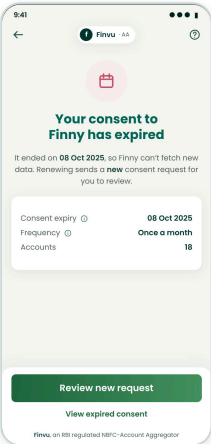
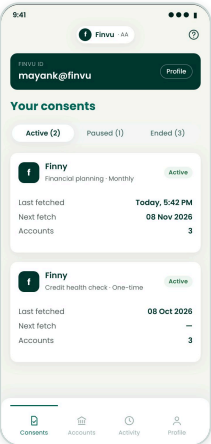
3. Point-by-point verification (Table 2)

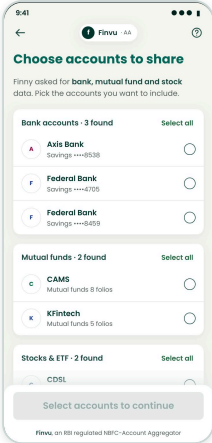
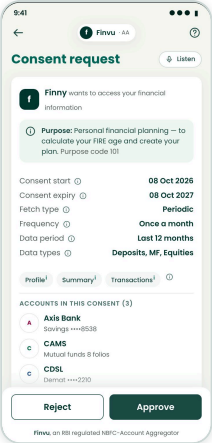
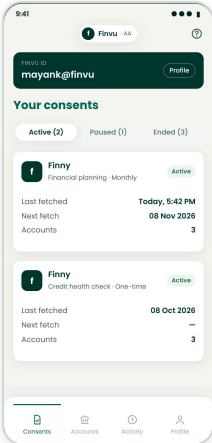
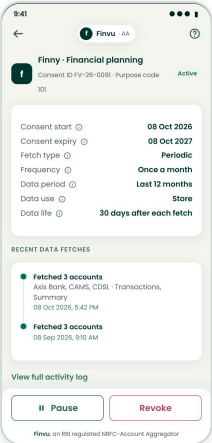
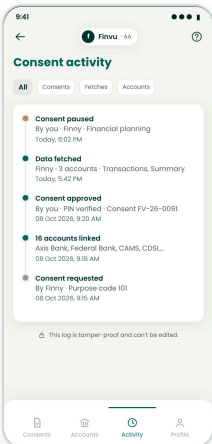
S.NO	POINT TO BE IMPLEMENTED	M/O	STATUS	OWNER	EVIDENCE SCREENS	REMARKS
Customer Onboarding						
1	Customer can link up to two mobile numbers for account discovery	M	Addressed	AA	07 08 38 §2.1.i	Second number added from identifiers or profile; limit of 2 stated; second SIM must be bound.
 07 4. Add identifiers (optional)  08 4b. Add a second mobile  38 Profile & VUA						
2	Optional identifiers (PAN / Date of Birth) for account discovery	M	Addressed	AA	07 20 §2.1.ii	PAN and DOB offered as opt-in (unticked) and suggested again when no accounts are found.
 07 4. Add identifiers (optional)  20 12. No accounts found						

S.NO	POINT TO BE IMPLEMENTED	M/O	STATUS	OWNER	EVIDENCE SCREENS	REMARKS
3	Authentication required for account delinking; ensure active consents revoked	M	Addressed	AA	35 36 37 §2.1	Delink disabled while a consent is active; OTP to the identifier used for linking.
					  	35 19. Delink account (blocked) 36 19b. Delink: verify 37 19c. Delinked
4	Customer profile captures minimum details (Name, Verified Mobile, Email) with masking	O	Addressed	AA	05 38 40 §2.2	Name, masked mobile, masked PAN and masked email shown; email optional at sign-up.
					  	05 3b. New user: create Finvu ID 38 Profile & VUA 40 Notification preferences
5	Virtual User Address (VUA) provided as unique identifier	M	Addressed	AA	04 05 28 38 §2.2.i, 4.2.vi	VUA created (editable, availability check) and shown on welcome, dashboard and profile.
					   	04 3. Existing Finvu account 05 3b. New user: create Finvu ID 28 17. Your consents (dashboard) 38 Profile & VUA

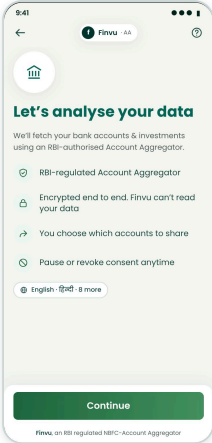
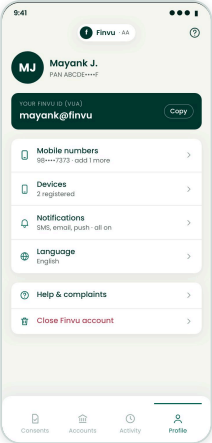
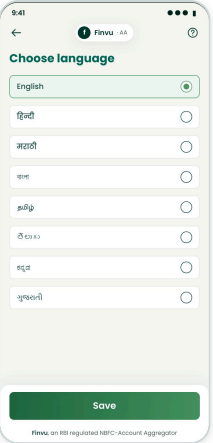
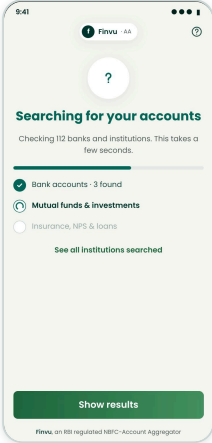
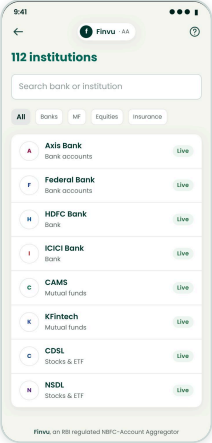
S.NO	POINT TO BE IMPLEMENTED	M/O	STATUS	OWNER	EVIDENCE SCREENS	REMARKS
6	AA Client checks if account already exists before onboarding	M	Addressed	AA	04 §2.2.ii	Existing Finvu account detected after mobile verification; "This isn't me" leads to recovery.
 04 3. Existing Finvu account						
Account Discovery						
7	Account closure facility with revocation of active consents and delinking of accounts	M	Addressed	AA	44 §2.2.iii	Shows consents to revoke and accounts to delink; explicit acknowledgement before closing.
 44 Close Finvu account						
8	Account recovery facility (digital/manual) with mobile verification	M	Addressed	AA	06 §2.2.iv	Digital recovery via registered SIM; manual route via support number shown.
 06 Recover account / reset PIN						

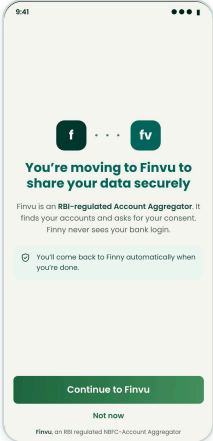
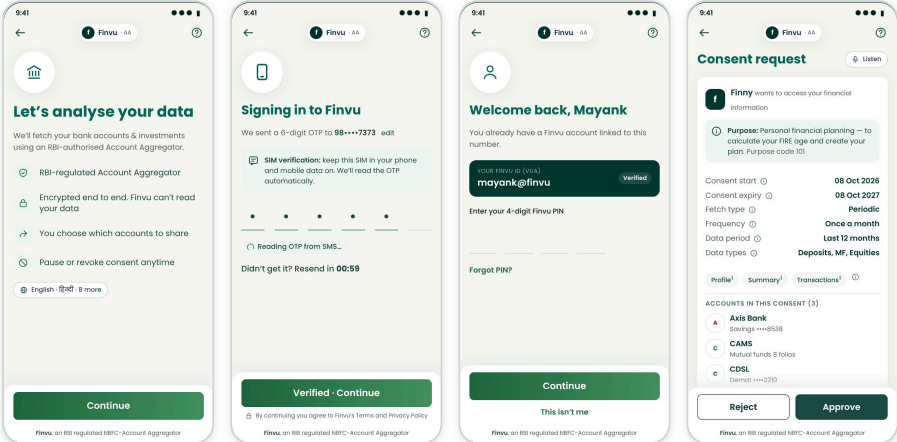
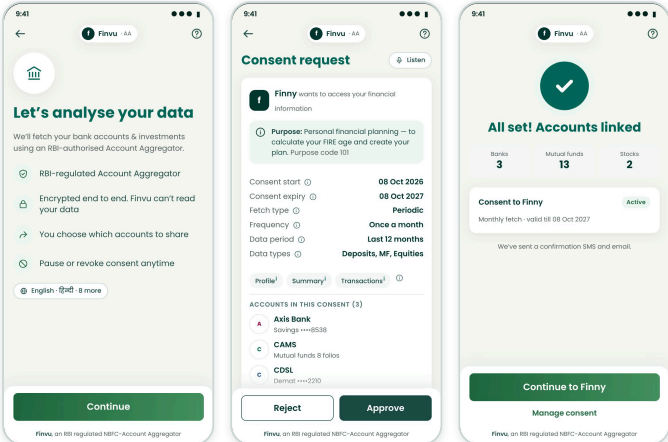
S.NO	POINT TO BE IMPLEMENTED	M/O	STATUS	OWNER	EVIDENCE SCREENS	REMARKS
Consent Management standards						
9	Clear presentation of consent fields (Start, Expiry, Fetch Type, FI Types, FI-U, Purpose, Data Range, Frequency)	M	Addressed	AA	12 14 §3.1.ii	All 8 mandatory fields visible above the decision; requester shown in header; purpose code shown.
	  12 7. Consent (summary) 14 7c. Two consents, decided separately					
10	Remaining consent fields shown via “View More”	M	Addressed	AA	12 13 §3.1.ii, 3.1.iii	“View all details” expands on the same screen: data use, data filter, data life, withdrawal and complaint links. Every field has a meaning sheet.
	  12 7. Consent (summary) 13 7b. What does this field mean?					
11	Voice-based reading of consent parameters	O	Addressed	AA	12 §3.1.v	“Listen” reads the mandatory fields aloud.
	 12 7. Consent (summary)					

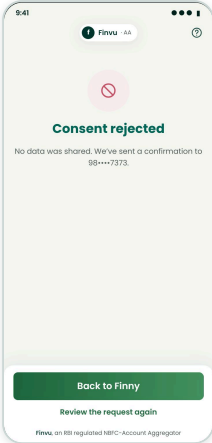
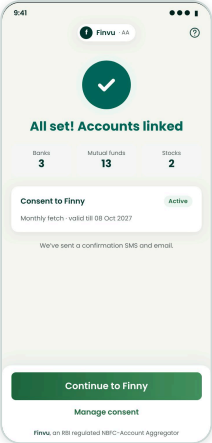
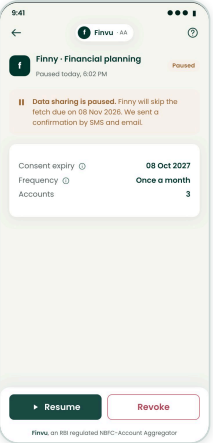
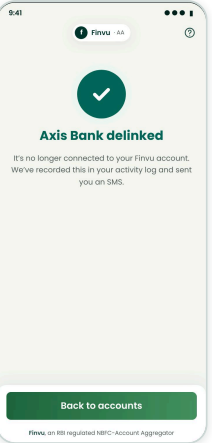
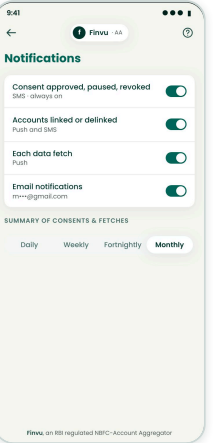
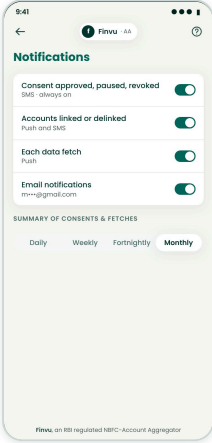
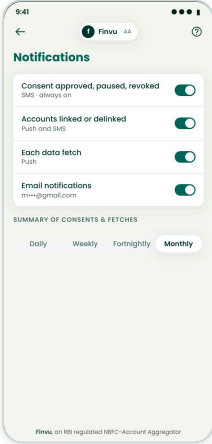
S.NO	POINT TO BE IMPLEMENTED	M/O	STATUS	OWNER	EVIDENCE SCREENS	REMARKS
12	Approve/Reject buttons equal size and visibility, no default pre-selection	M	Partial	AA	12 14 16 §3.2.iv, 3.2.v	Equal size and nothing pre-selected. Approve is filled and Reject outlined, which can be read as unequal visibility. Recommend matching visual weight (e.g. both outlined, or equal-contrast fills).
   12 7. Consent (summary) 14 7c. Two consents, decided separately 16 9. Reject confirmation						
13	Separate Approve/Reject for multiple consents	M	Addressed	AA	14 §3.2.vi	Each consent card has its own decision; continue enabled only when every consent is decided.
 14 7c. Two consents, decided separately						
14	Consent expiry mechanisms implemented	M	Addressed	AA	12 23 28 §3.2.vii	Expiry shown on request and dashboard; expired state with renewal as a new request.
   12 7. Consent (summary) 23 15. Consent expired 28 17. Your consents (dashboard)						

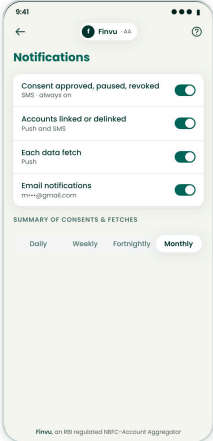
S.NO	POINT TO BE IMPLEMENTED	M/O	STATUS	OWNER	EVIDENCE SCREENS	REMARKS
15	Explicit account selection for consent approval (opt-in, no preselection)	M	Addressed	AA	10 12 §3.2.viii, 3.2.ix	No account pre-ticked (fixes current design); only FI types requested by Finny are listed; selected accounts repeated on the consent.
	 					
10 12	6. Choose accounts to link					
12 7	7. Consent (summary)					
16	Consent Dashboard showing active consents and data fetch history	M	Addressed	AA	28 29 §3.2.x	Active / Paused / Ended tabs, last and next fetch, per-consent fetch history.
	 					
28 17	17. Your consents (dashboard)					
29 17b	17b. Consent details & controls					
17	Tamper-proof audit trail of consent activities	M	Addressed	AA	33 §3.3.i	Append-only activity log with actor and timestamp. Tamper-proofing itself is a backend control.
						
33 18	18. Consent activity (audit trail)					

S.NO	POINT TO BE IMPLEMENTED	M/O	STATUS	OWNER	EVIDENCE SCREENS	REMARKS
18	Immutable consent artefacts	M	Addressed	AA	23 32 §3.3.ii	UI never edits a consent; changes and renewals raise a new request. Immutability enforced server-side.
23 15. Consent expired 32 17e. Revoke consent						
19	Robust security practices for consent (encryption, access controls, audits)	M	Engineering	AA	15 32 §3.3.iii	PIN confirmation for approve and revoke is designed; encryption and audits are engineering controls.
15 7d. Confirm consent 32 17e. Revoke consent						
User Experience Standards						
20	Simple and user-friendly design of AA Client	M	Addressed	AA	— §4.1.i, 4.1.ii, 4.1.v	Built on the Finny design system: one primary action per screen, bottom-anchored CTAs within thumb reach, plain-language copy.
21	Accessibility compliance (WCAG 2.0, alt text, contrast)	M	Partial	AA	— §4.1.iv	Tokens meet AA contrast for text; controls have labels. Pending: alt text for real illustrations and logos, screen-reader and large-font testing.

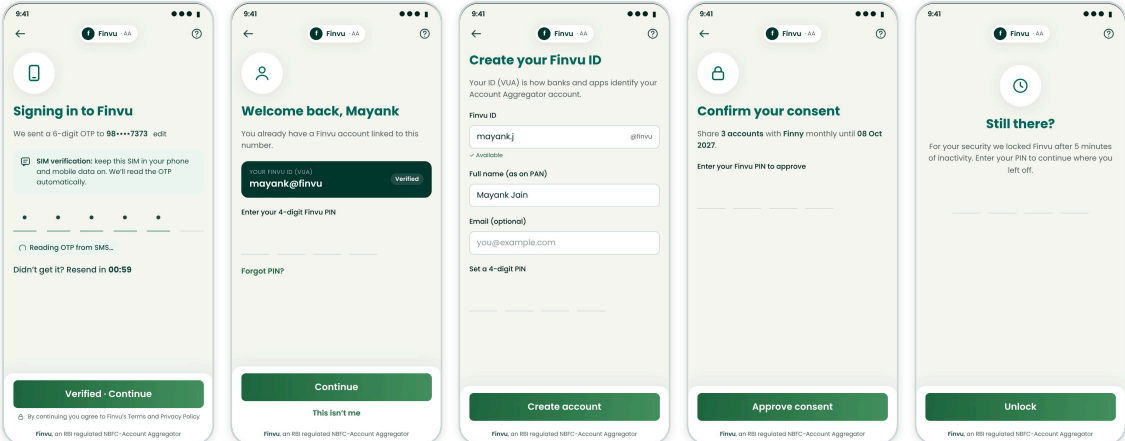
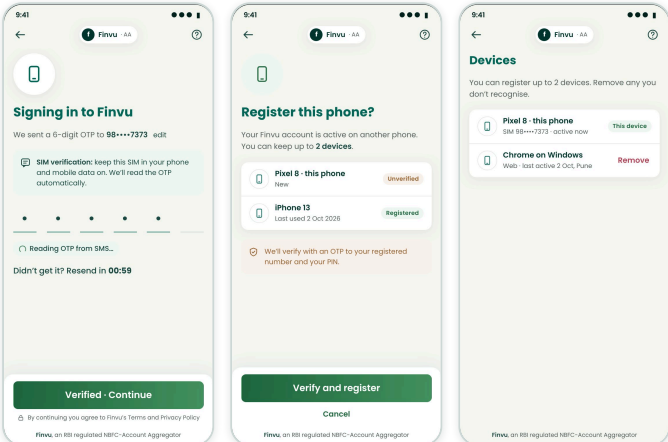
S.NO	POINT TO BE IMPLEMENTED	M/O	STATUS	OWNER	EVIDENCE SCREENS	REMARKS
22	Multi-language support	M	Addressed	AA	02 38 41 §4.1.vi	Language picker with 8 Indian languages in native script; reachable from intro and profile. Translations still to be produced.
   02 i. Intro 38 Profile & VUA 41 Language						
23	FI-P list visible to customers	M	Addressed	AA	09 45 §4.1.vii	Searchable list of institutions with live status, linked from discovery.
  09 5. Discovering accounts 45 Institutions on Finvu						
24	Usability testing and feedback mechanisms	M	Gap	AA	— §4.1.ix	No in-app feedback entry point designed. Add a lightweight rating or feedback prompt (e.g. after success and in Help) and plan usability tests.
No screen yet. Needs design.						

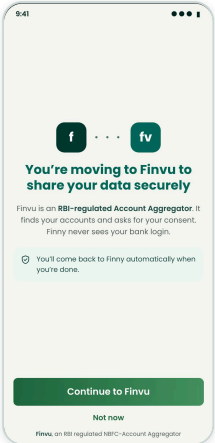
S.NO	POINT TO BE IMPLEMENTED	M/O	STATUS	OWNER	EVIDENCE SCREENS	REMARKS
25	FI-U informs users about redirection to AA Client	O	Addressed	FIU	01 §4.2.i, 4.2.ii	Hand-off screen explains the move to Finvu, why, and that the user returns automatically.
	 01 Hand-off to Account Aggregator					
26	AA Client displays name/logo prominently	M	Partial	AA	02 03 04 12 §4.2.iii	Finvu name shown top-centre on every AA screen, but as a small text chip. Replace with the official logo at a size that is clearly legible, especially on registration and login.
	 02 1. Intro 03 2. Verify mobile (SIM binding) 04 3. Existing Finvu account 12 7. Consent (summary)					
27	Tagline “RBI Regulated NBFC-AA” displayed	O	Addressed	AA	02 12 19 §4.2.iv	Footer tagline “Finvu, an RBI regulated NBFC–Account Aggregator” on every AA screen.
	 02 1. Intro 12 7. Consent (summary) 19 11. Success					

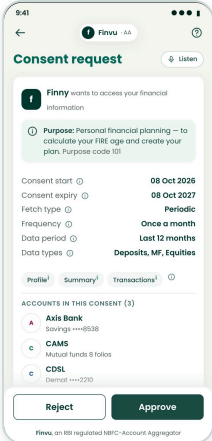
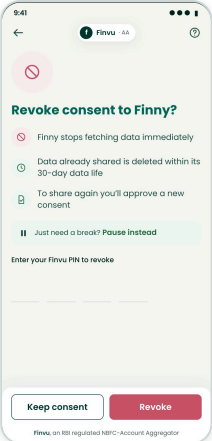
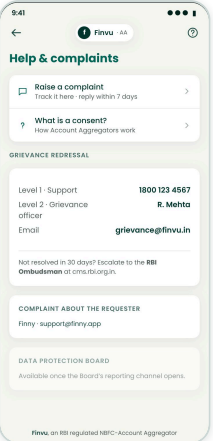
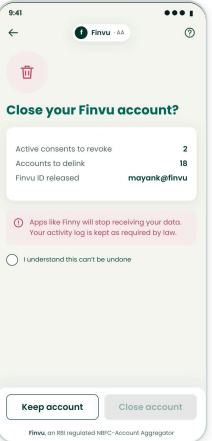
S.NO	POINT TO BE IMPLEMENTED	M/O	STATUS	OWNER	EVIDENCE SCREENS	REMARKS
28	Real-time notifications for account linking, consent approvals/revocations	M	Partial	AA	17 19 31 37 40 §4.3.i, 4.3.iii	Confirmations reference SMS/email and preferences exist. Not designed: push notification and SMS/email templates, and an in-app notification list.
					    	17 9b. Consent rejected 19 1i. Success 31 17d. Paused state 37 19c. Delinked 40 Notification preferences
29	Monthly SMS/email updates on active consents and data fetches	M	Partial	AA	40 §4.3.iv	Monthly summary set as default in preferences. Summary SMS/email content not designed.
						40 Notification preferences
30	FI-U provides data fetch summaries with customizable frequency	O	Partial	FIU	40 §4.3.v	Frequency choice (daily, weekly, fortnightly, monthly) shown on the AA side. Finny-side summary screen and setting not designed.
						40 Notification preferences

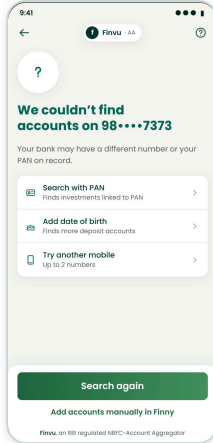
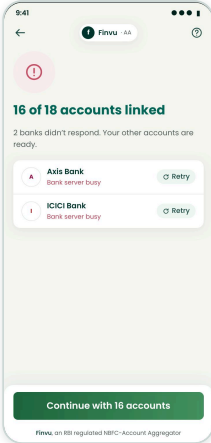
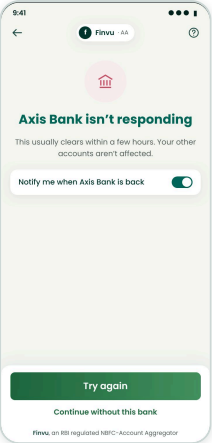
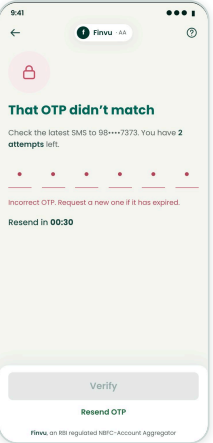
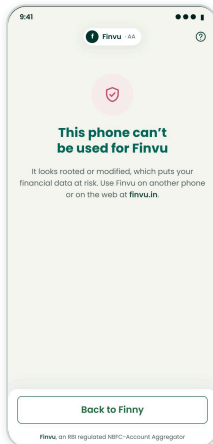
S.NO	POINT TO BE IMPLEMENTED	M/O	STATUS	OWNER	EVIDENCE SCREENS	REMARKS
31	Users can customize notification preferences	M	Addressed	AA	40 §4.3.vi	Channels and frequency configurable; all on by default; consent-change SMS cannot be turned off.
 40 Notification preferences						

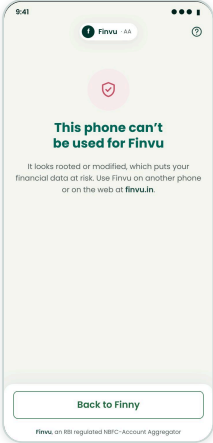
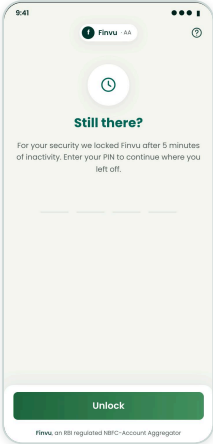
Technical, Security and Integration Standards

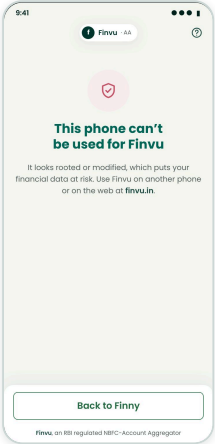
32	Two-Factor Authentication (2FA) implemented	M	Addressed	AA	03 04 05 15 25 §5.1.i	SIM-bound OTP plus Finvu PIN on sign-in; PIN re-asked for approve, revoke and unlock.
 03 2. Verify mobile (SIM binding) 04 3. Existing Finvu account 05 3b. New user: create Finvu ID 15 7d. Confirm consent 25 Session timed out						
33	SIM and device binding for mobile apps	M	Addressed	AA	03 26 39 §5.1.iii, 1.6	SIM verification on sign-in; new-device registration; device list.
 03 2. Verify mobile (SIM binding) 26 New device detected 39 Registered devices						

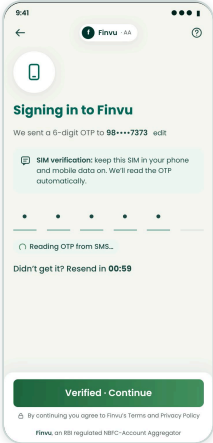
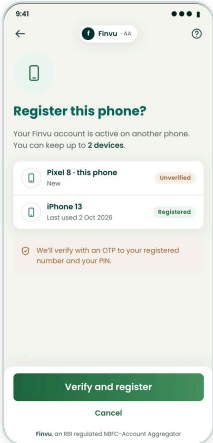
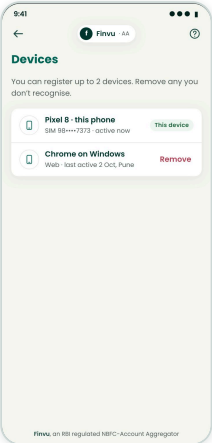
S.NO	POINT TO BE IMPLEMENTED	M/O	STATUS	OWNER	EVIDENCE SCREENS	REMARKS
34	Browser fingerprinting for web apps	M	Not in scope	AA	— §5.1.iv	Web app not covered by this mobile prototype.
35	CERT-In audit before production release and major updates	M	Engineering	AA	— §5.1.v	Process control.
36	Annual security assessments	M	Engineering	AA	— §5.1.vi	Process control.
37	Compliance with industry standards and regulations	M	Engineering	AA	— §5.1.vii	Process control.
38	Secure integration methods (Deep Linking, Redirection, SDK, iFrame)	M	Partial	Both	01 §5.2.i	User-facing hand-off designed. Integration choice and its fallback screens are engineering; see 98.
	 01 Hand-off to Account Aggregator					
39	Strong mutual authentication and encryption in integrations	M	Engineering	Both	— §5.2.ii	Engineering control.
40	Responsibilities defined when providing SDK	M	Engineering	AA	— §5.2.iii	Contractual / documentation control.
41	FI-U performs due diligence of AA SDK	M	Engineering	FIU	— §5.2.iv	Finny process control if the SDK route is used.
42	AA Client allows users to view/download financial data with explicit consent	O	Gap	AA	— §5.3	Optional feature not designed (customer as FI-U). If adopted, needs consent, view and download screens.
						
43	Data decrypted locally on customer device only	M	Not in scope	AA	— §5.3.i.f	Applies only if item 42 is implemented.
44	Downloaded files masked, password-protected, watermarked	M	Not in scope	AA	— §5.3.ii, 5.3.iii	Applies only if item 42 is implemented.

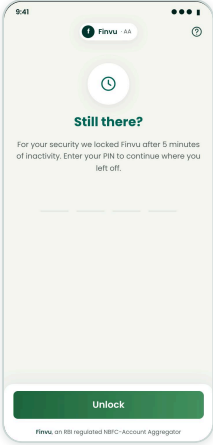
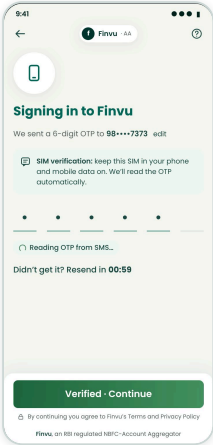
S.NO	POINT TO BE IMPLEMENTED	M/O	STATUS	OWNER	EVIDENCE SCREENS	REMARKS
45	Compliance with DPDP Act, 2023	M	Partial	Both	12 32 42 44 §5.5	Consent clarity, data life, withdrawal, complaints and account closure designed. Legal review and privacy notice pending; Data Protection Board link reserved.
    12 7. Consent (summary) 32 17e. Revoke consent 42 Help & complaints 44 Close Finvu account						
46	Secure communication protocols (TLS v1.2+)	M	Engineering	AA	— §Annex 1.1.1.i	Verify in engineering evidence.
47	Secure API integrations with authentication, authorization, input validation	M	Engineering	AA	— §Annex 1.1.1.ii	Verify in engineering evidence.
48	Certificate pinning or equivalent measures	M	Engineering	AA	— §Annex 1.1.1.iii	Verify in engineering evidence.
49	Robust encryption for sensitive data at rest/in transit	M	Engineering	AA	— §Annex 1.1.2.i	Verify in engineering evidence.
50	Secure key management practices	M	Engineering	AA	— §Annex 1.1.2.ii	Verify in engineering evidence.
51	Secure coding practices (input validation, output encoding, protection against XSS, injection)	O	Engineering	AA	— §Annex 1.1.3.i	Verify in engineering evidence.
52	Regular code reviews and security audits	M	Engineering	AA	— §Annex 1.1.3.ii	Verify in engineering evidence.
53	Comprehensive testing (functional, security, performance, compatibility)	M	Engineering	AA	— §Annex 1.1.4.i	Verify in engineering evidence.
54	Automated testing frameworks and CI practices	O	Engineering	AA	— §Annex 1.1.4.ii	Verify in engineering evidence.

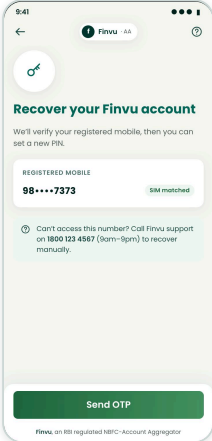
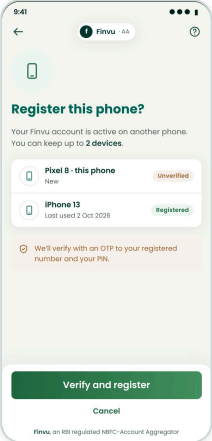
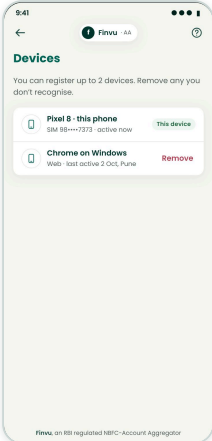
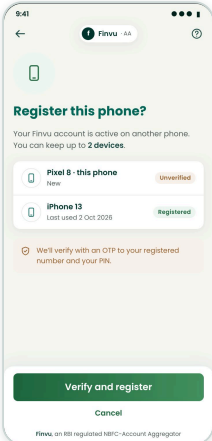
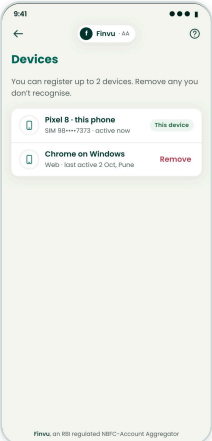
S.NO	POINT TO BE IMPLEMENTED	M/O	STATUS	OWNER	EVIDENCE SCREENS	REMARKS
55	Robust error handling without exposing debug logs	M	Addressed	AA	20 21 22 24 §Annex 1.1.5.i, ii	Every error state has a plain-language message and next step; no codes or traces shown. Logging itself is engineering.
    20 12. No accounts found21 13. Partial failure22 14. Bank unavailable24 16. OTP failed						
56	Logging with masked sensitive data	O	Engineering	AA	— §Annex 1.1.5.iv	Verify in engineering evidence.
57	Due diligence on third-party libraries/SDKs	M	Engineering	AA	— §Annex 1.1.6	Verify in engineering evidence.
58	Remote access disabled for mobile app	M	Engineering	AA	27 §Annex 1.2.1.i	Engineering. The “Device not secure” pattern can be reused when remote-access tools are detected.
 27 Device not secure						

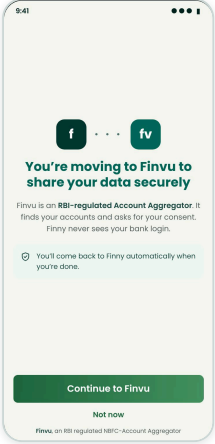
S.NO	POINT TO BE IMPLEMENTED	M/O	STATUS	OWNER	EVIDENCE SCREENS	REMARKS
59	Rooted/jailbroken devices blocked	M	Addressed	AA	27 §Annex 1.2.1.ii	Blocking screen with explanation and safe alternative; detection is engineering.
 27 Device not secure						
60	Secure push notifications	M	Engineering	AA	— §Annex 1.2.1.iii	Verify in engineering evidence.
61	Runtime Application Self-Protection (RASP)	M	Engineering	AA	— §Annex 1.2.1.iv	Includes screenshot blocking; no UI needed beyond OS behaviour.
62	Re-authentication after inactivity	M	Addressed	AA	25 §Annex 1.2.1.v	PIN unlock after 5 minutes idle; progress resumes.
 25 Session timed out						
63	Software Bill of Materials (SBOM) maintained	O	Engineering	AA	— §Annex 1.2.1.vi	Verify in engineering evidence.
64	Compatibility with latest Android/iOS versions	M	Engineering	AA	— §Annex 1.2.2.i	Verify in engineering evidence.
65	Regular updates for platform features/security patches	M	Engineering	AA	— §Annex 1.2.2.ii	Verify in engineering evidence.
66	Version governance to phase out old versions	M	Partial	AA	— §Annex 1.2.2.iii	Engineering. A forced-update screen exists in Finny (Launch designs “App update”) but not for the AA client.
67	Public checksum of active version hosted	O	Engineering	AA	— §Annex 1.2.2.iv	Verify in engineering evidence.
68	Web app input validation and output encoding	M	Not in scope	AA	— §Annex 1.3.1	Web app not covered.

S.NO	POINT TO BE IMPLEMENTED	M/O	STATUS	OWNER	EVIDENCE SCREENS	REMARKS
69	Web app performance optimization (loading times, caching)	O	Not in scope	AA	— §Annex 1.3.2	Web app not covered.
70	Use of CDNs for performance	O	Not in scope	AA	— §Annex 1.3.2.ii	Web app not covered.
71	Cross-browser compatibility testing	M	Not in scope	AA	— §Annex 1.3.3	Web app not covered.
72	Mobile SDK robust authentication mechanisms	M	Not in scope	AA	— §Annex 1.4.1.i	SDK not covered.
73	OAuth 2.0 for authorization	O	Not in scope	AA	— §Annex 1.4.1.ii	SDK not covered.
74	Secure token management (refresh, invalidate)	M	Not in scope	AA	— §Annex 1.4.1.iii	SDK not covered.
75	Secure storage (Keychain/Keystore)	O	Not in scope	AA	— §Annex 1.4.1	SDK not covered.
76	Access controls restricting SDK data access	M	Not in scope	AA	— §Annex 1.4.2.i	SDK not covered.
77	Encryption of SDK payloads	O	Not in scope	AA	— §Annex 1.4.2.ii	SDK not covered.
78	Regular vulnerability scans and patches for SDK	M	Not in scope	AA	— §Annex 1.4.2.iii	SDK not covered.
79	Secure integration mechanisms (API keys, client certificates)	M	Not in scope	Both	— §Annex 1.4.3.i	SDK not covered.
80	Security testing (penetration, code reviews)	M	Not in scope	AA	— §Annex 1.4.3.ii	SDK not covered.
81	Routed/jailbroken devices blocked for SDK	M	Addressed	AA	27 §Annex 1.4.3.iii	Same blocking screen applies when the flow runs inside Finny via SDK.
 27 Device not secure						
82	Comprehensive SDK documentation	M	Not in scope	AA	— §Annex 1.4.4.i	SDK not covered.
83	Developer support channels available	M	Not in scope	AA	— §Annex 1.4.4.ii	SDK not covered.
84	Adherence to Android/iOS guidelines	M	Partial	AA	— §Annex 1.4.5.i, 4.1.iii	Layouts follow mobile conventions (bottom actions, sheets, back). Native component mapping and platform review pending.

S.NO	POINT TO BE IMPLEMENTED	M/O	STATUS	OWNER	EVIDENCE SCREENS	REMARKS
85	Regular SDK updates	M	Not in scope	AA	— §Annex 1.4.5.ii	SDK not covered.
86	PKI for sensitive data (OTPs, PINs, passwords)	O	Engineering	AA	— §Annex 1.5.1	Verify in engineering evidence.
87	PKI digital signatures for authenticity/integrity	O	Engineering	AA	— §Annex 1.5.2	Verify in engineering evidence.
88	SIM binding via outgoing SMS + OTP auto-read	M	Partial	AA	03 §Annex 1.6.1.i, 1.6.3.iv	OTP auto-read with manual entry disabled is designed. Missing: the step where the app sends the outgoing SMS (with SMS-charge notice and SIM picker for dual-SIM phones).
 03 2. Verify mobile (SIM binding)						
89	Device binding via unique identifiers	M	Addressed	AA	26 39 §Annex 1.6.1.ii	Unregistered device triggers OTP + PIN; identifier generation is engineering.
  26 New device detected 39 Registered devices						
90	Browser fingerprinting for web apps	M	Not in scope	AA	— §Annex 1.6.2.i	Web app not covered.

S.NO	POINT TO BE IMPLEMENTED	M/O	STATUS	OWNER	EVIDENCE SCREENS	REMARKS
91	Session security with device-bound tokens  25 Session timed out	M	Engineering	AA	25 §Annex 1.6.2.ii	Engineering; re-authentication UI exists.
92	Strong encryption of device identifiers	M	Engineering	AA	— §Annex 1.6.3.i	Verify in engineering evidence.
93	Mandatory mobile data during binding  03 2. Verify mobile (SIM binding)	M	Partial	AA	03 §Annex 1.6.3.ii	Instruction shown. Missing: blocking state when mobile data is off or Wi-Fi only.
94	Restriction on app toggling during binding No screen yet. Needs design.	M	Gap	AA	— §Annex 1.6.3.iii	No screen tells the user to stay in the app or handles them leaving mid-binding. Add a “Don’t switch apps” notice and a restart state.

S.NO	POINT TO BE IMPLEMENTED	M/O	STATUS	OWNER	EVIDENCE SCREENS	REMARKS
95	Fallback authentication for SIM/device changes	M	Partial	AA	06 26 §Annex 1.6.3.v	Device change and recovery designed. Missing: SIM-swapped / number-changed state and re-binding flow.
	  06 Recover account / reset PIN 26 New device detected					
96	Device visibility for customers	M	Addressed	AA	39 §Annex 1.6.3.vi	All devices and web sessions listed with remove action.
	 39 Registered devices					
97	Limit on number of device bindings per user	M	Addressed	AA	26 39 §Annex 1.6.3.vii	Limit of 2 shown; adding beyond limit requires removing a device.
	  26 New device detected 39 Registered devices					

S.NO	POINT TO BE IMPLEMENTED	M/O	STATUS	OWNER	EVIDENCE SCREENS	REMARKS
Baseline Integration method						
98	Deep Linking integration (URL schema, Intents, Universal Links, secure tokens, fallback, user choice)	M	Partial	Both	01 §Annex 2.1	Hand-off designed. Missing FI-U screens: choose among integrated AA apps (2.1.f) and "AA app not installed" store fallback with deferred deep link (2.1.e).
						
	01 Hand-off to Account Aggregator					
99	Secure SDK integration with FI-U apps	M	Not in scope	Both	— §Annex 2.2	Engineering; the same screens apply inside the SDK.
100	Secure iFrame integration with AA Web App	M	Not in scope	Both	— §Annex 2.3	Web app not covered.
101	Secure redirection with FI-U Web App	M	Not in scope	Both	— §Annex 2.4	Web app not covered.

Appendix A. Screen index

Each prototype screen and the Table 2 points it provides evidence for.

#	SCREEN	REVIEW PDF PAGE	EVIDENCE FOR S.NO
01	Hand-off to Account Aggregator	3	25, 38, 98
02	1. Intro	4	22, 26, 27
03	2. Verify mobile (SIM binding)	5	26, 32, 33, 88, 93
04	3. Existing Finvu account	6	5, 6, 26, 32
05	3b. New user: create Finvu ID	7	4, 5, 32
06	Recover account / reset PIN	8	8, 95
07	4. Add identifiers (optional)	9	1, 2
08	4b. Add a second mobile	10	1
09	5. Discovering accounts	11	23
10	6. Choose accounts to link	12	15
11	6b. Confirm with bank OTP	13	Supports other items
12	7. Consent (summary)	14	9, 10, 11, 12, 14, 15, 26, 27, 45
13	7b. What does this field mean?	15	10
14	7c. Two consents, decided separately	16	9, 12, 13
15	7d. Confirm consent	17	19, 32
16	9. Reject confirmation	18	12
17	9b. Consent rejected	19	28
18	10. Connecting accounts	20	Supports other items
19	11. Success	21	27, 28
20	12. No accounts found	22	2, 55
21	13. Partial failure	23	55
22	14. Bank unavailable	24	55
23	15. Consent expired	25	14, 18
24	16. OTP failed	26	55
25	Session timed out	27	32, 62, 91
26	New device detected	28	33, 89, 95, 97
27	Device not secure	29	58, 59, 81
28	17. Your consents (dashboard)	30	5, 14, 16
29	17b. Consent details & controls	31	16
30	17c. Pause consent	32	Supports other items
31	17d. Paused state	33	28
32	17e. Revoke consent	34	18, 19, 45

#	SCREEN	REVIEW PDF PAGE	EVIDENCE FOR S.NO
33	18. Consent activity (audit trail)	35	17
34	Linked accounts	36	Supports other items
35	19. Delink account (blocked)	37	3
36	19b. Delink: verify	38	3
37	19c. Delinked	39	3, 28
38	Profile & VUA	40	1, 4, 5, 22
39	Registered devices	41	33, 89, 96, 97
40	Notification preferences	42	4, 28, 29, 30, 31
41	Language	43	22
42	Help & complaints	44	45
43	Raise a complaint	45	Supports other items
44	Close Finvu account	46	7, 45
45	Institutions on Finvu	47	23

Reviewed by (Design)

Reviewed by (Compliance)

Date